INFORMATION AND CYBER SECURITY
ANSWER KEY – R24

PART – A (5 × 1 = 5 Marks)

1(a) Define Firewall.

A firewall is a network security device or software that monitors and controls incoming and outgoing network traffic based on predefined security rules. It protects a network from unauthorized access.

1(b) Define Cyber Security Audit.

Cyber Security Audit is the systematic inspection of an organization's computer systems, applications, operating systems and security controls to identify security flaws and check whether security requirements are followed.

1(c) Recall the different ways in which an asset is classified.

According to Unit IV, information assets are classified into four categories: (1) Highly Restricted, (2) Confidential, (3) Internal Use Only and (4) Public.

1(d) What is the need for security policies?

Security policies are needed to increase efficiency, maintain discipline and accountability, protect sensitive information, educate employees about security and protect the organization's business interests.

1(e) Define a Software License.

A software license is a legally binding document that provides guidelines for the use and distribution of software. It defines the rights and responsibilities of software developers and users.

PART – B (5 × 5 = 25 Marks)

2. Develop the necessary steps to be taken for the configuration of a firewall.

A firewall is a network security device or software that monitors and controls incoming and outgoing network traffic based on predefined security rules. Proper firewall configuration protects computers and networks from unauthorized access, malware and cyberattacks.

1. Define Security Policy: Identify which services and applications are allowed, determine which traffic should be blocked and establish security requirements. Example: Allow HTTP (Port 80) and HTTPS (Port 443), and block Telnet (Port 23).

2. Choose the Firewall Type: Select an appropriate firewall based on organizational needs: Packet Filtering Firewall, Stateful Inspection Firewall, Proxy Firewall or Next-Generation Firewall (NGFW).

3. Configure Network Interfaces: Assign firewall interfaces to different network zones: Internal Interface (LAN) for the trusted network, External Interface (WAN) for the Internet connection and DMZ Interface for public-facing servers.

4. Configure Firewall Rules: Create rules that define which traffic is allowed or denied. Rule components include source IP address, destination IP address, protocol (TCP/UDP/ICMP), port number and action (Allow or Deny).

5. Configure Network Address Translation (NAT): NAT hides internal IP addresses, allows multiple devices to share a public IP address and protects internal network information.

6. Enable Logging and Monitoring: Record allowed and blocked traffic, monitor suspicious activities and generate security alerts.

7. Enable Intrusion Detection/Prevention: Some firewalls include an Intrusion Detection System (IDS) and Intrusion Prevention System (IPS). These features detect and block known cyberattacks.

8. Test Firewall Rules: Verify that authorized traffic is allowed, unauthorized traffic is blocked and applications function correctly. Testing tools include Ping, Nmap, Telnet and Wireshark.

9. Regular Maintenance: Update firewall firmware and software, review rules periodically, remove unused or outdated rules, back up configuration and monitor security logs.

Conclusion: Proper firewall configuration prevents unauthorized access, controls network traffic and improves organizational network security.

OR

3. Explain the types, functions and advantages of proxy servers.

Definition: A proxy server is a computer or software that acts as an intermediary between a client and a destination server. It receives requests from clients, processes them and forwards them to the appropriate web server.

Working of Proxy Server

1. A client sends a request to access a website.
2. The request is received by the proxy server.
3. The proxy checks the request against security policies.
4. If permitted, the proxy forwards the request to the destination server.
5. The destination server sends the response to the proxy.
6. The proxy forwards the response back to the client.

Types of Proxy Servers

1. Forward Proxy: Represents clients and is used to access Internet resources securely.

2. Reverse Proxy: Represents servers and protects web servers and balances incoming traffic.

3. Transparent Proxy: Intercepts traffic without changing client settings; commonly used for web filtering and caching.

4. Anonymous Proxy: Hides the client's IP address while identifying itself as a proxy.

5. High-Anonymity (Elite) Proxy: Hides the client's identity and the use of a proxy.

Functions

- Hides the client's IP address.
- Filters Internet traffic.
- Blocks unauthorized websites.
- Caches frequently accessed web pages.
- Improves browsing speed.
- Monitors and logs user activity.
- Enhances network security.

Advantages

- Enhances security.
- Provides web filtering.
- Improves performance through caching.
- Hides client IP addresses.
- Reduces bandwidth usage.
- Monitors Internet usage.

Disadvantages

- May slow down network performance.
- Incorrect configuration can create security risks.
- Free proxies may not be trustworthy.
- Some websites block proxy traffic.

Conclusion: Proxy servers improve security, privacy and Internet access control by acting as intermediaries between clients and destination servers.

4. Explain Risk Assessment and Risk Management.

Risk Assessment: Cyber Security Risk Assessment is the process of identifying, analyzing and evaluating risks. It helps to ensure that the cyber security controls selected are appropriate for the risks faced by an organization.

Examples of Cyber Risks: Data leaks, phishing, malware, ransomware, insider threats and cyberattacks.

Step 1: Determine the Scope: Decide which part of the organization needs assessment. It may include the entire organization, a business unit, a location or a web application.

Step 2: Identify Cyber Security Risks: Identify assets by creating an inventory of physical and logical assets; identify threats that can harm assets; identify vulnerabilities; and identify the consequences if a threat exploits a vulnerability.

Step 3: Analyze Risks and Determine Potential Impact: Determine the likelihood of a risk occurring and identify its impact on the organization.

Step 4: Determine and Prioritize Risks: Use a risk matrix: Risk Level = Likelihood × Impact. Classify and prioritize risks according to severity.

Step 5: Document All Risks: Maintain a risk register containing the risk scenario, identification date, existing controls, current risk level, treatment plan, progress status, residual risk and risk owner.

Example: Threat – attacker performs SQL Injection; Vulnerability – unpatched web server; Asset – web server; Consequence – stealing customers' private data.

Risk Treatment Methods

Avoid: Stop the activity if the risk is greater than its benefits.

Transfer: Share the risk with another party through insurance or outsourcing.

Mitigate: Apply security controls to reduce the likelihood or impact of the risk.

Risk Management: Risk management is the process of identifying, evaluating, prioritizing and treating risks to reduce their impact on an organization.

Conclusion: Risk assessment and risk management help organizations identify security weaknesses, reduce cyber risks and protect important information.

OR

5. What are the 5 C's of a Crisis Management Plan? Identify the most important part of a crisis plan.

Crisis Management Plan: A crisis management plan outlines how an organization will respond if a crisis occurs. It identifies who will take action and what their roles will be. The main goal is to minimize damage and restore business operations as quickly as possible.

The five stages of the Crisis Management Cycle (as given in Unit IV):

1. Identifying the Crisis: Identify the nature of the crisis. Types include natural crisis, organizational misdeed crisis, deception crisis, workplace violence crisis, skewed values crisis and rumours crisis.

2. Preparing for the Crisis: Prepare a proper plan before a crisis occurs. Operational planning explains what is done, who does it and when. Communication planning explains what is said, who says it and how messages are delivered.

3. Preventing the Crisis: Anticipate and have a plan; respond immediately; do not overtalk; always tell the truth; and accept responsibility.

4. Responding to the Crisis: Effective response includes planning scenarios, response modules, preset activation protocols and clear communication channels.

5. Recovering from the Crisis: Continue business during the crisis, plan recovery from damage, implement the recovery plan and restore normal business operations.

Most Important Part: Effective communication is a very important part of crisis management because it helps share correct information, avoid confusion and coordinate the response.

Note: The supplied Unit IV material describes these five stages, rather than a separate list called the five C's.

6. Differentiate Penetration Testing and Vulnerability Testing.

Penetration Testing: It is the process of actively testing the security of an information system by attempting to exploit vulnerabilities under authorized conditions to evaluate the effectiveness of security controls.

Vulnerability Testing: It is the process of identifying, analyzing and evaluating security weaknesses in computer systems, networks, applications and devices.

Penetration Testing	Vulnerability Testing
1. It simulates an attack by a malicious hacker.	1. It identifies security weaknesses.
2. It attempts to exploit vulnerabilities.	2. It generally does not exploit vulnerabilities.
3. It evaluates the impact of successful attacks.	3. It assesses the severity of vulnerabilities.
4. It checks the effectiveness of security controls.	4. It prioritizes vulnerabilities based on risk.
5. It provides recommendations to improve security.	5. It recommends fixing security weaknesses.
6. It requires skilled professionals.	6. It commonly uses automated scanning tools.

Types of Penetration Testing

Black Box Testing: The tester has no prior knowledge of the system.

White Box Testing: The tester has complete knowledge of the system.

Gray Box Testing: The tester has partial knowledge of the system.

Types of Vulnerability Testing: Network, host-based, web application, wireless, database and mobile application vulnerability testing.

Conclusion: Both testing methods help identify security weaknesses and improve the security of an organization's systems.

OR

7. What is Security Logging and Analysis? Explain its benefits.

Definition: Security Logging and Analysis is the process of recording, monitoring and analyzing security events in an organization to identify unauthorized activities and protect information systems. Every activity in an organization, such as emails, logins and firewall updates, is considered a security event.

How Does It Work?

7. Security events are recorded in log files.
8. Organizations monitor the log files.
9. Electronic audit log files are examined for unauthorized activities.
10. Suspicious activities are identified.
11. The collected data is moved to a central database for further investigation.
12. Necessary action is taken to protect the system.

Important Events Identified Through Log Analysis

1. Reconnaissance: Attackers collect information about the organization's environment.

2. Weaponization: Attackers prepare an attack against the network or IT systems.

3. Delivery: An exploit is delivered against a vulnerability.

4. Installation of Malware: Malware is installed to maintain access.

5. Command and Control: Attackers gain control of servers and systems.

6. Action Begins: The attacker starts performing malicious activities.

Benefits of Security Logging and Analysis

1. Detection of Security Breaches: Protects against malicious external threats and internal misuse of information.

2. Event Reconstruction: Audit trails help reconstruct events leading to an intrusion, understand how a breach occurred and identify and rectify vulnerabilities.

3. Faster Recovery: Audit logs help create a fast and effective recovery process, reconstruct lost or corrupted data files and reduce business downtime.

Conclusion: Security logging and analysis help organizations detect security breaches, investigate attacks and recover systems quickly.

8. Explain the following: (a) WWW Policy (b) Email Security Policy.

(a) WWW Policy

WWW stands for World Wide Web. It is a system of information available over the Internet. The web is constructed using web servers that make information available on the network. Web browsers are used to access information stored on servers.

Security Policies Applied on WWW:

- No offensive or harassing material should be available through the company website.
- No personal commercial advertising should be available on the company website.
- Personal material should be kept to a minimum on the website.
- No confidential company information should be made available.
- Users of an organization should not be permitted to install or run a web server.

Example: An employee should not upload confidential company documents to the organization's public website.

(b) Email Security Policy

An email security policy is a series of procedures governing the use of emails within a network or organization. It explains how users should interact with messages that are sent and received through email. Its goal is to protect email messages from unauthorized access.

Important Elements of Email Security Policy:

- Scope and purpose of the policy.
- Ownership of email content.
- Privacy concerns and expectations.
- Responsibilities of email users.
- Guidelines for using organizational email accounts.
- Tips to detect and avoid email security threats.
- Actions to take during a suspected email security breach.
- Training for email users.

Steps to Build an Effective Email Security Policy:

13. Adopt a template.
14. Modify the template according to organizational needs.
15. Identify user engagement terms.
16. Implement security tools such as spam filters and malware prevention software.
17. Enforce user policy acknowledgement.
18. Train users.
19. Develop an incident response plan.

Conclusion: WWW policies protect company websites, while email security policies protect organizational email communication and confidential information.

OR

9. Compare and contrast Corporate Policies and Sample Security Policies with a suitable example.

A. Corporate Policy

Definition: Corporate policy is a formal declaration of principles and procedures according to which a company operates. These principles and guidelines are executed by the board of directors, senior management and policy committee.

Corporate Policy Includes:

- Company mission statement.
- Company objectives.
- Principles on the basis of which strategic decisions are made.

Importance of Corporate Policy:

- Helps perform business activities smoothly.
- Provides clear directions for achieving organizational goals.
- Helps employees and management make decisions.
- Promotes allocation of decision-making power.
- Provides stability to organizational activities.
- Helps analyze employee performance.
- Improves employee commitment and loyalty.
- Helps in the proper utilization of resources.
- Develops a good public image of the organization.
- Helps in coordination and control.

B. Sample Security Policy

A sample security policy is a document that describes the rules, responsibilities and procedures required to protect an organization's information and systems.

Main Components of a Sample Security Policy:

- Information Security Policy: aim, purpose and responsibilities of users.
- Risk Assessment and Classification: risk assessment of information and personal data.
- Protection of Information Systems and Assets.
- Protection of Confidential Information.
- Risk Identification and Analysis: threats and risks.
- Appendix: sample risk assessment.
- Glossary.

Difference Between Corporate Policy and Sample Security Policy

Corporate Policy	Sample Security Policy
1. Defines company principles and procedures.	1. Defines information security rules and guidelines.
2. Focuses on achieving organizational goals.	2. Focuses on protecting information and systems.
3. Includes mission and objectives.	3. Includes aim, purpose and user responsibilities.
4. Guides management and employees.	4. Guides users in protecting company information.
5. Helps in coordination and control.	5. Helps in risk identification and protection of assets.

Suitable Example

Corporate Policy: A company provides guidelines for employee attendance, working hours and organizational objectives.

Sample Security Policy: A company instructs employees to use strong passwords, protect confidential information and avoid suspicious email attachments.

Conclusion: Corporate policies guide the overall functioning of an organization, whereas security policies specifically protect its information and IT assets.

10. Explain about IT Act 2000 Provisions.

Introduction: The Information Technology Act, 2000 (IT Act 2000) is the primary law in India for matters related to cybercrime and electronic commerce. It was officially passed in 2000 and amended in 2008. Its main aim is to provide legal recognition to electronic transactions and prevent cybercrime.

Objectives of IT Act 2000

- To provide legal recognition to electronic transactions.
- To give legal recognition to digital signatures.
- To provide legal recognition to electronic accounting records.
- To protect online privacy.
- To prevent cybercrimes.
- To promote electronic commerce and electronic governance.

Important Provisions of IT Act 2000

Section	Provision
Section 43	Unauthorized access, damage or deletion of computer data; compensation may be imposed.
Section 43A	Compensation for failure to protect sensitive personal data through reasonable security practices.
Section 65	Tampering with computer source documents.
Section 66	Computer-related offences involving dishonest or fraudulent acts.
Section 66B	Receiving stolen computer resources or communication devices.
Section 66C	Identity theft.
Section 66D	Cheating by personation using computer resources.
Section 66E	Violation of privacy.
Section 66F	Cyber terrorism.
Section 67	Publishing or transmitting obscene material in electronic form.
Section 69	Government power to issue directions for interception, monitoring or decryption, subject to legal conditions.

Punishments Mentioned in the Study Material

- Section 66: Up to 3 years imprisonment or fine up to Rs. 5 lakh or both.
- Sections 66B, 66C and 66D: Up to 3 years imprisonment or fine up to Rs. 1 lakh or both.
- Section 66E: Up to 3 years imprisonment or fine up to Rs. 2 lakh or both.
- Section 66F: Life imprisonment.
- Section 67: Up to 5 years imprisonment or fine up to Rs. 10 lakh or both, as stated in the Unit V table.

Schedules of IT Act 2000

First Schedule: Deals with documents to which the Act shall not apply.

Second Schedule: Deals with electronic signature or electronic authentication methods.

Conclusion: The IT Act 2000 provides legal protection for electronic transactions, digital signatures and computer systems. It also provides penalties for various cybercrimes in India.

OR

11. Define Copyright Law. Briefly explain its effects.

Definition: Copyright law is a type of Intellectual Property Right (IPR) that protects the original creative work of authors, artists, musicians, designers and other creators. It gives creators exclusive rights to control how their work is copied, distributed and made public.

Copyright Act in India

- The Copyright Act, 1957 governs copyright law in India.
- It came into effect on 21 January 1958.
- It was amended six times since 1957.
- The most recent amendment mentioned in the study material was in 2012.

Objectives of Copyright Law

- To protect the rights of authors and creators.
- To encourage creativity and innovation.
- To prevent unauthorized copying.
- To reward creative individuals.
- To protect intellectual property.

Nature of Copyright

- Copyright is an incorporeal property.
- The owner has exclusive rights over the created work.
- The owner can assign or license the copyright.
- Copyright has a limited period of protection.
- After the protection period, the work enters the public domain.

Eight Categories of Copyright-Protected Works

20. Literary works.
21. Musical works.
22. Dramatic works.
23. Pantomimes and choreographic works.
24. Pictorial, graphic and sculptural works.
25. Motion pictures and audiovisual works.
26. Sound recordings.
27. Architectural works.

Copyright Does Not Protect

- Ideas.
- Procedures.
- Processes.
- Systems.
- Methods of operation.

- Concepts.
- Principles.
- Names and titles.
- Short phrases.

Examples of Copyright Violations

- Copying books without permission.
- Recording music or videos without authorization.
- Copying copyrighted software illegally.
- Publishing another person's creative work without permission.

Effects of Copyright Protection

- Protects the creator's rights.
- Prevents unauthorized copying and distribution.
- Encourages creativity and innovation.
- Provides legal protection against copyright infringement.
- Allows creators to earn benefits from their work.

Conclusion: Copyright law protects original creative works and provides creators with legal rights over their work.